NEXUS FINANCIAL SERVICES

Risk-Based Annual Audit Plan and ISO/IEC 27001 Audit Program

Audit Cycle 1: 1 November 2026 to 31 October 2027

Prepared by	Maureen Uzoewulu, Junior GRC Analyst
Prepared for	Executive Management and the Audit and Risk Committee, Nexus Financial Services
Date	30 October 2026
Status	Proposal for review and approval
Classification	Internal

Table of Contents

1. Executive Summary 3
2. Part A: Risk-Based Annual Audit Plan 4

2.1 Audit Engagement Details 4
2.2 Purpose and Objectives 4
2.3 Scope and Criteria 5
2.4 Audit Universe, Risk Ranking and Priority 5
2.5 Justification of Results 8
2.6 Proposed 12-month Audit Schedule 9
2.7 Resource Allocation 10
2.8 Responsibilities 12
2.9 Reporting and Follow-Up 13

Plan Approval 13

1. Executive Summary

Nexus Financial Services is a Lagos-based financial services company with 150 employees, $800M in assets, cloud-based applications, remote staff and payment systems. It is preparing for its annual internal audit cycle and an ISO/IEC 27001 Information Security Management System (ISMS) review. Management has raised six concerns: employees keep system access after changing roles, quarterly access reviews are not completed consistently, security incident records are incomplete, supplier security assessments are overdue, weaknesses from the previous audit remain unresolved, and the internal audit team cannot examine every area at once.

This report provides two linked documents:

- **Part A: Risk-Based Annual Audit Plan.** It ranks 12 auditable areas by risk score (likelihood × impact) and selects the five highest-risk areas for full audits within the available capacity. It sets objectives, scope and criteria, a 12-month schedule and 48 planned auditor-days, plus an 8-day contingency.
- **Part B: ISO/IEC 27001 Audit Program.** It defines the program objectives and the proposed ISMS scope, and maps each audit area to ISO/IEC 27001:2022 Clauses 4 to 10 and the relevant Annex A controls. It sets out the frequency, methods, responsibilities, test steps and evidence required for six audit procedures (AP-01 to AP-06), along with reporting, corrective action and follow-up arrangements.

2. Part A: Risk-Based Annual Audit Plan

2.1 Audit Engagement Details

Field	Entry
Organization	Nexus Financial Services, Lagos, Nigeria
Audit Period	12-month cycle: 1 November 2026 to 31 October 2027 (proposed)
Sponsor/Approver	Chief Executive Officer (sponsor); Audit and Risk Committee of the Board (approver)
Audit lead/Team	Head of Internal Audit (lead auditor); IT Auditor; co-sourced ISO/IEC 27001 Lead Auditor (technical specialist)
Audit type	Risk-based internal audit (compliance, technical and follow-up audits) and ISO/IEC 27001:2022 ISMS internal audit
Planning basis	Management concerns, risk assessment, previous audit findings, regulatory and contractual obligations (NDPA 2023, CBN cybersecurity requirements where applicable, PCI DSS), and ISMS documentation

2.2 Purpose and Objectives

To focus limited audit resources first on the security and compliance weaknesses that pose the greatest risk to Nexus, and to give management and the Board evidence-based assurance before the ISO/IEC 27001 ISMS review.

1. Determine whether access management removes access promptly after role changes and departures, and whether quarterly access reviews are completed and acted on.
2. Assess whether security incidents are recorded completely and tracked through classification, escalation, response, closure and lessons learned.
3. Determine whether supplier security assessments are current and whether identified supplier risks are managed.
4. Verify the status and effectiveness of corrective actions from the previous audit.
5. Evaluate conformity with relevant ISMS requirements (Clauses 4–10) and the operation of applicable Annex A controls within the approved ISMS scope.

2.3 Scope and Criteria

Field	Entry
Scope	Access management; incident management and records; supplier security; previous audit findings and corrective actions; ISMS governance, risk management and the Statement of Applicability.
Systems/Locations	Cloud-based applications, payment systems, identity and remote-access services, the IT service desk and incident tools, and the Lagos headquarters, including remote staff. Remote auditing methods are used for remote staff and cloud consoles. Exact systems and interfaces are to be confirmed in Month 1.
Period under review	1 November 2025 to 31 October 2026 for initial testing; later audits extend the period up to their fieldwork date.
Criteria	ISO/IEC 27001:2022 Clauses 4–10; applicable Annex A controls based on risk treatment and the approved SoA; Nexus policies, procedures and contracts; the NDPA 2023; CBN cybersecurity requirements where they apply to Nexus's license; PCI DSS for cardholder data.
Exclusions/Limitations	Areas ranked 6–12 are not audited in full this cycle (see Section 3.5). Audit capacity is limited to 56 auditor-days. Exclusions from the ISMS boundary are to be confirmed and justified in Month 1. Samples and dates are confirmed during engagement planning.

2.4 Audit Universe, Risk Ranking and Priority

Scoring method: L - Likelihood (1–5) × I - Impact (1–5) = risk score (1–25).

Rating bands: **Critical** 21–25; **High** 15–20; **Medium** 8–14; **Low** 1–7.

Scores account for management concerns, previous findings, regulatory and contractual obligations, recent changes and emerging threats, and are supported by professional judgement.

Rank	Auditable Area	L	I	Risk Score	Rationale
1	Access lifecycle and access reviews	5	5	25 (Critical)	Management confirms that employees keep access after role changes and that quarterly reviews are missed. The control failure is already occurring (L5). Excess access to payment systems, customer data and cloud applications can lead to fraud, data breaches and NDPA or PCI DSS exposure.
2	Previous audit findings and corrective actions	4	5	20 (High)	Known weaknesses remain unresolved, so the risk is confirmed and may be repeating. Unaddressed root causes undermine every other control, and they weaken Clause 10.2 conformity and Board confidence.
3	Incident records and management	4	5	20 (High)	Incomplete records weaken investigation, escalation and lessons learned. It also threatens regulatory reporting: personal data breaches may need to be reported to the NDPC within 72 hours, and cyber incidents to the CBN within 24 hours where applicable.
4	Supplier security assessments	4	4	16 (High)	Assessments are overdue, so cloud, payment and ICT supplier risks may be unidentified.

					Impact is high but partly reduced by contracts and supplier certifications.
5	ISMS governance, risk and SoA alignment	3	5	15 (High)	The ISMS review requires the scope, risk treatment and SoA to be aligned. Weaknesses here would undermine certification readiness and every control audit.
6	Payment systems security	3	5	15 (High)	High impact, but there is no specific management concern. Covered through AP-01 (privileged access to payment systems) and AP-04 (payment processors).
7	Cloud application security and configuration	3	4	12 (Medium)	Cloud access is tested in AP-01 and the cloud provider in AP-04. A full configuration audit is deferred.
8	Remote access and endpoint security	3	4	12 (Medium)	Remote MFA and VPN access are sampled in AP-01. Endpoint baselines are deferred.
9	Logging and monitoring	3	4	12 (Medium)	Partly covered in AP-03 by reconciling security alerts with incident tickets.
10	Business continuity and backup	2	5	10 (Medium)	No current concern. Management monitors test results, and a full audit is planned for the next cycle.

11	Security awareness and training	3	3	9 (Medium)	Clause 7.2 and 7.3 records are checked within AP-05. A full audit is deferred.
12	Physical security (Lagos office)	3	3	9 (Medium)	Cloud-based operations reduce exposure. Deferred, with reliance on facilities management reporting.

2.5 Justification of Results

Priorities reflect risk level, previous findings, regulatory deadlines, business cycles, resource availability and dependencies:

- **Confirmed failures come first.** Areas 1–4 are existing control failures reported by management, not possible risks, so their likelihood is rated 4 or 5.
- **Access is audited first** because it carries the highest score and gives direct access to money and personal data. The results will also inform the incident and supplier audits.
- **Previous findings are reviewed early** because unresolved root causes may explain several of the current concerns, and the follow-up evidence supports Clause 10.2 before the ISMS review.
- **The ISMS governance audit is placed after the control audits** so that it can test whether the risk register and SoA reflect what the control audits find, and so that its results feed the management review (Clause 9.3).
- **Coverage over depth for areas 6–9:** high-impact areas without specific concerns are tested through targeted samples inside the five main audits, so capacity is not spread thin.
- **The plan is reviewed** if a significant incident, regulatory change or major system change alters Nexus's risk profile. The 8-day contingency funds unplanned or event-triggered audits.

2.6 Proposed 12-month Audit Schedule

Month	Dates	Activity	Focus/Output	Effort (auditor – days)
1	Nov 2026	Planning and scoping	Confirm the ISMS boundary, criteria, SoA, risk register, prior reports, contacts and system access. Rapid status check of overdue previous findings. Opening meeting.	3
2 - 3	Dec 2026 – Jan 2027	AP-01 Access management	Role changes, leavers, approvals, privileged access, quarterly reviews and exception handling.	10
4	Feb 2027	AP-02 Previous findings follow-up	Verify implementation and effectiveness of overdue corrective actions. Results support the annual CBN self-assessment due by 28 February, where applicable.	5
5 - 6	Mar – Apr 2027	AP-03 Incident management	Incident procedure, register completeness, classification, escalation, response and closure. Timed to support the NDPA compliance audit return due 31 March.	7
7 - 8	May – Jun 2027	AP-04 Supplier security	Supplier inventory, risk tiers, due diligence, contracts, assessments and action tracking.	6

9	Jul 2027	AP-05 ISMS governance, risk and SoA	Clauses 4–10, risk treatment, SoA rationale and alignment with the control audit results.	6
10	Aug 2027	AP-05 ISMS governance, risk and SoA	Retest High and Critical findings from AP-01 to AP-04 whose actions are due.	5
11	Sep 2027	Reporting	Validate evidence, consolidate findings, agree action owners and due dates, and give input to the ISMS management review.	4
12	Oct 2027	Annual close-out	Review outstanding actions, residual risks, lessons learned and next-cycle priorities. Annual report to the Audit and Risk Committee.	2
		Contingency	Event-triggered audits, such as after a significant incident, or extended testing	8

Effort figures are estimates and should be adjusted for team size, complexity and evidence availability. If significant risks or incidents arise, the plan is rescheduled with the approval of the Audit and Risk Committee.

2.7 Resource Allocation

This shows how the internal audit team's limited time is divided across the year's audits. Time is counted in auditor-days, meaning one auditor working one day. The section answers three questions: who does the work, how much time each audit gets, and how much time is held back for surprises.

Engagement	Head of Internal Audit	IT Auditor	Co-sourced specialist	Total
Planning and scoping	2	1	0	3
AP-01 Access management	2	6	2	10
AP-02 Previous findings	2	3	0	5
AP-03 Incident management	2	4	1	7
AP-04 Supplier security	2	4	0	6
AP-05 ISMS governance, risk and SoA	1	1	4	6
AP-06 Retesting	1	3	1	5
Reporting	2	2	0	4
Annual close-out	1	1	0	2
Planned total	15	25	8	48
Contingency	3	5	0	8
Available capacity	18	30	8	56

Competence and independence: the co-sourced specialist leads AP-05 because the GRC function maintains the ISMS documents and cannot audit its own work. The IT Auditor carries out technical access testing with read-only system access. The Junior GRC Analyst coordinates evidence requests and maintains the corrective-action tracker but does not audit areas the GRC function owns. Allocation considers competence, independence, specialist support, system access and budget.

2.8 Responsibilities

Role	Responsibility
Audit and Risk Committee / CEO	Approve the plan and resources; resolve access barriers; receive significant findings, escalations and quarterly progress reports.
Head of Internal Audit (lead auditor)	Manage scope, criteria, schedule, workpapers, quality review, findings and reporting; confirm auditor independence.
IT Auditor	Perform technical testing and sampling for AP-01 to AP-04 and AP-06; prepare workpapers.
Co-sourced ISO/IEC 27001 Lead Auditor	Lead AP-05; support technical testing; remain independent of the controls assessed.
GRC / ISMS representative (incl. Junior GRC Analyst)	Provide the ISMS scope, risk register, SoA, policies, prior reports and corrective-action records; coordinate evidence requests; maintain the action tracker.
Head of IT / identity and access owner	Provide user and role listings, approvals, provisioning and deprovisioning logs, privileged-account data and review evidence.
Head of HR	Provide records of joiners, role changes and leavers for reconciliation with access.
CISO / incident response commander	Provide the incident procedure, register, case records, alert data, and escalation and closure evidence.
Procurement / vendor manager	Provide the supplier inventory, criticality ratings, assessments, contracts and the overdue assessment tracker.
Data Protection Officer	Provide breach-notification records and NDPA compliance evidence.

2.9 Reporting and Follow-Up

Each engagement follows the planning, preparation, fieldwork, reporting and follow-up cycle:

- Hold an opening meeting for each engagement to confirm objectives, scope, criteria, contacts, schedule and evidence handling.
- Record each test and evidence reference in workpapers, keeping verified facts separate from explanations and assumptions.
- Discuss factual accuracy with process owners at a closing meeting before findings are finalised.
- Document each finding using criteria, condition, evidence, risk or impact, cause and corrective action.
- Assign an accountable action owner and due date for each finding, and escalate significant or overdue issues to the Audit and Risk Committee.
- Verify implementation and effectiveness through evidence and retesting, then update the finding status and next-cycle priorities.

Plan Approval

Approval	Name/Role	Signature	Date
Prepared by	Maureen Uzoewulu, Junior GRC Analyst		30/10/2026
Reviewed by	Head of Internal Audit		
Approved by	Chair, Audit and Risk Committee		

3. Part B: ISO/IEC 27001 Audit Program

The annual plan schedules and prioritizes the engagements. The audit program sets out how they are carried out: the objectives, criteria, methods, evidence and responsibilities that together satisfy ISO/IEC 27001:2022 Clause 9.2.2 (internal audit programme). It follows ISO 19011:2026 guidance on establishing, implementing, monitoring and improving an audit program. The distinction between the program and individual audit plans, and the mapping of requirements to audit activities, follows the ISO 27001 audit program guidance.

3.1 Program Header

Field	Entry
Program owner/Period	Head of Internal Audit; 1 November 2026 to 31 October 2027
Objectives	Assess conformity with ISO/IEC 27001:2022 Clauses 4–10; test whether selected Annex A controls are implemented and operating effectively; identify gaps and verify corrective actions; provide input to the ISMS management review.
Methods	Document review, interviews, observation, sampling, walkthroughs (on-site and remote) and authorised control testing.
Criteria	ISO/IEC 27001:2022 clauses; Annex A controls that apply under the SoA and risk treatment plan; Nexus policies, procedures and contracts; the NDPA 2023, CBN requirements where applicable, and PCI DSS.
Independence	Auditors do not audit their own work. The co-sourced specialist leads the ISMS governance audit. Conflicts and safeguards are recorded in each engagement file.
Evidence handling	Unique workpaper IDs (WP-AP-01 to WP-AP-06); each item records its source, date, sample and custodian. Evidence is stored in a restricted internal audit repository with role-based access, kept for 7 years, and handled as Confidential, since it contains personal data.

3.2 Audit objectives and ISMS Scope

3.2.1 Program Objectives

1. Confirm that the ISMS scope, risk assessment, risk treatment and SoA are documented, approved and consistent with each other (Clauses 4.3, 6.1.2, 6.1.3).
2. Determine whether access, incident and supplier controls operate as designed and address management's concerns.
3. Verify that nonconformities from the previous audit have been corrected and their root causes removed (Clause 10.2).
4. Provide reliable results to the management review (Clause 9.3) and the Audit and Risk Committee.

3.2.2 ISMS Scope Statement

The ISMS covers the people, processes, information and technology that support the delivery of Nexus Financial Services' financial services from its Lagos headquarters and by remote staff. This includes cloud-based applications, payment systems, identity and remote-access services, incident management, and the suppliers that provide cloud, payment and ICT services. Interfaces with customers, regulators and suppliers are included up to the point where Nexus's responsibility ends.

3.3 Applicable ISO/IEC 27001 Clauses

Field	Entry	
4 Context	4.1 Issues; 4.2 Interested parties (regulators, customers, suppliers); 4.3 ISMS scope; 4.4 ISMS	AP-05; AP-04 (suppliers as interested parties)
5 Leadership	5.1 Leadership and commitment; 5.2 Policy; 5.3 Roles, responsibilities and authorities	AP-05

6 Planning	6.1.2 Risk assessment; 6.1.3 Risk treatment and SoA; 6.2 Objectives; 6.3 Planning of changes	AP-05; risk links tested in AP-01, AP-03, AP-04
7 Support	7.2 Competence; 7.3 Awareness; 7.5 Documented information (completeness of records)	AP-03 (incident records); AP-05
8 Operation	8.1 Operational planning and control; 8.2 Risk assessment performed; 8.3 Risk treatment implemented	AP-01, AP-03, AP-04
9 Performance Evaluation	9.1 Monitoring and measurement; 9.2 Internal audit; 9.3 Management review	AP-05; the program itself (9.2)
10 Improvement	10.1 Continual improvement; 10.2 Nonconformity and corrective action	AP-02, AP-06

3.4 Relevant Annex A Controls

Annex A controls are audited only where the SoA records them as applicable. The controls below are proposed because they relate directly to management's concerns; they are not assumed to apply automatically.

Audit Area	ISO/IEC 27001:2022 Annex A controls
AP-01 Access lifecycle and reviews	A.5.15 Access control A.5.16 Identity management A.5.17 Authentication information A.5.18 Access rights (provisioning, review, removal) A.5.3 Segregation of duties A.6.5 Responsibilities after termination or change of employment A.8.2 Privileged access rights A.8.5 Secure authentication
AP-02 Previous findings	Clause 10.2 (primary criterion)

	A.5.35 Independent review of information security A.5.36 Compliance with policies, rules and standards for information security Plus the controls named in each original finding
AP-03 Incident records	A.5.24 Incident management planning and preparation A.5.25 Assessment and decision on information security events A.5.26 Response to information security incidents A.5.27 Learning from information security incidents A.5.28 Collection of evidence A.6.8 Information security event reporting A.8.15 Logging A.8.16 Monitoring activities A.5.34 Privacy and protection of PII (breach notification)
AP-04 Supplier security	A.5.19 Information security in supplier relationships A.5.20 Addressing information security within supplier agreements A.5.21 Managing information security in the ICT supply chain A.5.22 Monitoring, review and change management of supplier services A.5.23 Information security for use of cloud services
AP-05 ISMS governance, risk and SoA	A.5.1 Policies for information security A.5.2 Information security roles and responsibilities A.5.4 Management responsibilities A.5.9 Inventory of information and other associated assets A.5.31 Legal, statutory, regulatory and contractual requirements A.6.3 Information security awareness, education and training
AP-06 Retest	The controls linked to each finding being retested.

3.5 Audit Frequency, Methods and Responsibilities

Audit Area	Timing and frequency / trigger	Methods	Auditor/ Auditee Owner
AP-01 Access lifecycle and reviews	Months 2–3. Annual, with a repeat test within 6 months after serious failures, major system changes or recurring exceptions. Management's quarterly reviews remain an operational control; the audit does not replace them.	Document review; HR-to-system reconciliation (data analytics); sampling; system walkthrough (remote screen share); re-performance of a review	IT Auditor (lead), specialist / Head of IT, Head of HR
AP-02 Previous findings	Month 4, then according to risk and action due dates. Significant findings are escalated and verified promptly.	Document review; interviews with action owners; re-performance of original tests	Head of Internal Audit / action owners
AP-03 Incident management	Months 5–6. Annual, plus an event-triggered review after a significant incident or recurring gaps in records.	Document review; sampling; alert-to-ticket reconciliation; interviews; observation of triage	IT Auditor / CISO, DPO

AP-04 Supplier security	Months 7–8. Annual, prioritising critical suppliers and overdue assessments.	Document review; contract inspection; sampling; interviews	IT Auditor / procurement and vendor manager
AP-05 ISMS governance, risk and SoA	Month 9. Annual, and when material scope, risk-treatment or ISMS changes occur.	Document review; interviews with leadership; tracing risks to treatment and the SoA	Co-sourced specialist / CISO, GRC
AP-06 Retest and close-out	Months 10–12, based on action due dates, severity and evidence of recurrence.	Re-performance; sampling; document review	IT Auditor, Head of Internal Audit / action owners

Using several evidence sources (records, interviews, observation, sampling and testing) together lets auditors corroborate one source with another and distinguish a control that exists on paper from one that actually operates.

3.6 Detailed Audit Procedures and Evidence Required

The procedures below complete the detailed audit procedures and evidence matrix (AP-01 to AP-06).

AP-01 Access Lifecycle and Access Reviews	
Objective	Confirm that access is granted on approval, changed or removed promptly when roles change or staff leave, and reviewed every quarter.
Criteria	Clauses 6.1.3, 8.1, 9.1; A.5.15–A.5.18, A.5.3, A.6.5, A.8.2, A.8.5; Nexus Access Control Policy and Joiner-Mover-Leaver (JML) procedure; PCI DSS access requirements for payment systems.
Test steps	• Walk through the JML process with HR, IT and the service desk. • Reconcile the HR list of role changes and leavers with active accounts on in-scope systems.

	• For sampled role changes, trace the request, approval, removal of old access and completion date. • Compare current permissions with the role matrix for sampled users. • Inspect all four quarterly reviews for each in-scope system: completion, reviewer sign-off and exception follow-up. • Review the privileged-account list and MFA enforcement, including remote and cloud console access.
Evidence required	• User and role listings exported by the auditor or observed during export • HR role-change and leaver reports • Access requests and approvals • Provisioning and deprovisioning logs • Privileged-account inventory • MFA configuration reports • Quarterly access review records and sign-offs • Exception tickets and closure evidence
Sampling	Risk-based: 25 role changes and 25 leavers (or 100% if fewer); 100% of privileged accounts; 4 quarters for each in-scope system.
Responsibility	IT Auditor (lead), co-sourced specialist; auditees: Head of IT, Head of HR.
Result record	WP-AP-01; sample list; exceptions; finding IDs.

AP-02 Previous Audit Findings and Corrective Actions	
Objective	Verify that previous findings have been corrected, their root causes addressed, and the fixes are effective.
Criteria	Clause 10.2; A.5.35, A.5.36; commitments in the previous audit report; the corrective-action procedure.
Test steps	• Obtain the previous findings register and confirm the owner, root-cause analysis, action, due date and status for each finding. • Inspect implementation evidence for all overdue and High or Critical findings. • Re-perform the original test to confirm effectiveness, not just completion. • Identify recurring findings and escalate overdue actions.
Evidence required	• Previous audit report • Corrective-action tracker • Root-cause analyses • Remediation tickets • Updated policies or configurations • Retest evidence and approval records
Sampling	100% of open High or Critical and overdue findings; a risk-based sample of findings marked closed.
Responsibility	Head of Internal Audit; auditees: action owners.
Result record	WP-AP-02; updated status; escalation record.

AAP-03 Security Incident Records and Management	
Objective	Assess whether incidents are recorded completely and managed through to closure and lessons learned, and whether regulatory notifications are made on time.

Criteria	Clauses 7.5, 8.1, 9.1, 10.2; A.5.24–A.5.28, A.6.8, A.8.15, A.8.16, A.5.34; Nexus incident response procedure; NDPA breach notification; CBN incident reporting where applicable.
Test steps	• Review the incident procedure for severity definitions, mandatory record fields and notification timelines. • Reconcile security alerts and service-desk tickets with the incident register to find unrecorded incidents. • Trace sampled incidents through detection, classification, ownership, escalation, response, closure and post-incident review. • Check that mandatory fields are complete and that regulatory notifications met their deadlines.
Evidence required	• Incident response plan • Incident register • Incident tickets • Security alert and SIEM records • Escalation communications • Response timelines • Closure approvals • Post-incident reviews • Breach notifications to regulators and individuals
Sampling	25 incidents across severity levels and types, including open and closed cases; 100% of High-severity incidents and personal data breaches.
Responsibility	IT Auditor; auditees: CISO, DPO.
Result record	WP-AP-03; completeness exceptions; finding IDs.

AAP-04 Supplier Security	
Objective	Determine whether supplier security assessments are current and whether supplier risks are identified, contracted for and managed.
Criteria	Clauses 4.2, 6.1, 8.1; A.5.19–A.5.23; the supplier security policy and contracts.
Test steps	• Obtain the supplier inventory and confirm the criticality rating method. • Identify critical and high-risk suppliers (cloud, payment, ICT). • For sampled suppliers, verify due diligence, contract security clauses (breach notice, audit rights, data location, exit), the current assessment date and remediation tracking. • Investigate overdue assessments and confirm whether interim risk acceptance was approved.
Evidence required	• Supplier inventory and criticality ratings • Due-diligence questionnaires • Assessments and supplier certificates (e.g., ISO/IEC 27001, PCI DSS Attestation of Compliance) • Contracts and SLAs • Risk acceptance records • Remediation tracker • Review dates
Sampling	100% of critical suppliers; a risk-based sample of 10 other suppliers; 100% of overdue assessments.
Responsibility	IT Auditor; auditee: procurement and vendor manager.
Result record	WP-AP-04; overdue list; risk and action references.

AP-05 ISMS Governance, Risk and SoA	
Objective	Evaluate conformity with Clauses 4–10 and confirm that the scope, risk treatment and SoA are aligned.
Criteria	Clauses 4–10; A.5.1, A.5.2, A.5.4, A.5.9, A.5.31, A.6.3; Annex A controls only where applicable under the SoA.
Test steps	• Confirm the approved ISMS scope and boundaries. • Inspect the risk assessment and treatment records, roles, objectives, monitoring, internal audit and management review records. • Trace selected risks (access, incidents, suppliers) to their treatment decisions and to SoA inclusion or exclusion. • Check that control audit findings appear in the risk register.
Evidence required	• ISMS scope document • Policies • Roles and responsibilities • Risk assessment and risk treatment plan • SoA • Objectives and KPIs • Monitoring results • Training records • Management review and internal audit records • Register of legal requirements
Sampling	10 risks linked to the case concerns; all SoA exclusions.
Responsibility	Co-sourced specialist; auditees: CISO, GRC.
Result record	WP-AP-05; confirmation of scope and criteria; gaps and actions.

AP-06 Follow-Up and Effectiveness Retest	
Objective	Confirm that corrective actions from this cycle and the previous one are implemented and effective.
Criteria	Clause 10.2; the corrective-action procedure; the criteria of each original finding.
Test steps	• For findings marked complete, obtain current evidence and repeat the original test. • Determine whether the root cause was addressed and whether the issue has recurred. • Record residual risk or ineffective actions and escalate as required.
Evidence required	• Corrective-action records • Implementation evidence • Updated access reviews, incident logs or supplier assessments • Retest results • Approvals
Sampling	All High and Critical findings due for verification; a risk-based selection of the others.
Responsibility	IT Auditor and Head of Internal Audit; auditees: action owners.
Result record	Retest workpaper; effective or ineffective status; finding closed or reopened.

3.7 Reporting, Corrective Actions and Follow-Up

3.7.1 Reporting Timeline per Engagement

Step	Timing and Recipient
Closing meeting	Within 2 working days of the end of fieldwork, with the process owners
Draft report	Within 10 working days of fieldwork, to the process owners and CISO
Management responses	Within 10 working days of the draft, giving actions, owners and due dates
Final report	Within 5 working days of receiving responses, to the CEO and the Audit and Risk Committee
Progress reporting	Quarterly to the Audit and Risk Committee: plan status, findings, overdue actions, scope changes
Management review input	Consolidated audit results, nonconformity trends and action status for the ISMS management review (Clause 9.3), Month 11

3.7.2 Finding Classification and Corrective-Action Deadlines

Rating	Meaning	Corrective Action Due
Critical / Major nonconformity	A requirement is not met, or a control is absent or failing systemically, with high exposure (e.g., repeated access retained after role change)	Containment within 5 working days; action within 30 days
High / Minor nonconformity	An isolated lapse in meeting a requirement	60 days
Medium / Observation	A weakness that could lead to nonconformity if not addressed	90 days

Low / Opportunity for improvement	A possible improvement in efficiency or good practice	180 days, or as agreed

3.7.3 Corrective Action and Follow-Up Process

1. The action owner contains the issue, analyses the root cause (for example, using the 5 Whys) and proposes a corrective action that addresses the cause, not just the symptom.
2. Internal Audit agrees the action, owner and due date, and GRC records them in the corrective-action tracker.
3. The owner submits evidence of implementation by the due date. Extensions need CISO approval and are reported to the committee.
4. Internal Audit retests the control (AP-06). Findings close only when the control is shown to be effective; otherwise, they are reopened and escalated.
5. Actions overdue by more than 30 days and all ineffective Critical actions are escalated to the Audit and Risk Committee.
6. Recurring themes feed the next risk assessment and next year's audit plan.

3.8 Program Monitoring and Improvement

In line with ISO 19011:2026, the program owner monitors the program quarterly and reviews it annually, using these measures:

- % of planned engagements completed on schedule (target at least 90%)
- % of final reports issued within the agreed timelines
- % of corrective actions closed by their due date and verified as effective
- Auditee feedback and auditor competence and independence confirmations
- Scope changes and the use of contingency days

3.9 Program Reporting and Approval

Field	Entry
Opening meeting date / attendees	9 November 2026 (proposed): CEO, CISO, Head of IT, Head of HR, procurement and vendor manager, DPO, GRC, Internal Audit
Workpaper / evidence register location	Restricted internal audit repository (access limited to Internal Audit)
Progress / scope changes	Logged with change, reason, approver and date; material changes approved by the Audit and Risk Committee
Significant issue escalation	Head of Internal Audit to the CEO and the Audit and Risk Committee Chair within 2 working days of identifying a Critical issue, by written memo
Draft / final report dates	Per the engagement timeline (Section 4.7); annual report in October 2027
Corrective-action tracker owner	GRC function (Junior GRC Analyst maintains it; Head of Internal Audit verifies closure)
Program review and approval	Head of Internal Audit (owner); approved by the Audit and Risk Committee: [approval reference and date]

4. Conclusion

The risk-based annual plan directs Nexus's limited audit capacity to its most serious exposures, starting with access control, followed by previous findings and incident records, then supplier security and ISMS governance. The ISO/IEC 27001 audit program supports this with clear criteria, defined evidence and a closed-loop corrective-action process, so that Nexus enters its ISMS review with verified, evidence-based assurance.

References

1. 10Alytics. (2026). Nexus Financial Services: Audit plan and audit program templates [Course document].
2. Bello-Abubakar, A. (2026). Security audit and assurance [Lecture slides, GRC C26-07, Class 5]. 10Alytics.
3. Central Bank of Nigeria. (2024). Risk-Based Cybersecurity Framework and Guidelines for Deposit Money Banks and Payment Service Banks. https://www.cbn.gov.ng/Out/2024/BSD/CBN%20Risk-Based%20Cybersecurity%20Framework%20for%20DMBs%20and%20PSBs_2024.pdf
4. Federal Republic of Nigeria. (2023). Nigeria Data Protection Act, 2023 (Act No. 37). https://ndpc.gov.ng/wp-content/uploads/2024/03/Nigeria_Data_Protection_Act_2023.pdf
5. Elias. (2024). Overview of the CBN Risk-Based Cybersecurity Framework and Guidelines. https://www.gelias.com/images/Newsletter/_Overview_of_the_CBN_Risk-Based_Cyber_Security_Framework.pdf
6. International Organization for Standardization. (2022). ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection: Information security management systems: Requirements. https://www.iso.org/standard/27001
7. International Organization for Standardization. (2026). ISO 19011:2026 Guidelines for auditing management systems. https://committee.iso.org/sites/tc176/home/news/content-left-area/news-and-updates/iso-19011-2026-released.html
8. ISACA. (n.d.). IT Audit Framework (ITAF) and IT audit resources. https://www.isaca.org/resources/it-audit
9. Nigeria Data Protection Commission. (n.d.). Frequently Asked Questions. https://ndpc.gov.ng/faqs/
10. PCI Security Standards Council. (n.d.). PCI DSS Document Library. https://www.pcisecuritystandards.org/document_library/
11. The Institute of Internal Auditors. (2024). Global Internal Audit Standards. https://www.theiia.org/en/standards/2024-standards/global-internal-audit-standards/